

Acme Corporation Legal and Compliance Manual

Policy Manual — Edition 2024

1. Data Retention

Customer personal data is retained for the duration of the contract plus 90 days. Backups are retained for 35 days on a rolling basis. Financial records are retained for 7 years in accordance with statutory requirements. Deletion requests from data subjects must be fulfilled within 30 days.

The data classification framework is expanded to include a fifth tier: Regulated. Regulated data includes health information, financial account numbers, and government identifiers, and is subject to the strictest controls.

2. GDPR Compliance

Acme processes personal data of EU residents under the lawful bases of contract performance, legitimate interest, and consent. The Data Protection Officer can be reached at dpo@acmecorp.example. Data Processing Agreements are required with all sub-processors. Cross-border transfers rely on Standard Contractual Clauses and the EU-US Data Privacy Framework.

3. Global Privacy Compliance

Acme complies with GDPR (EU), UK GDPR, CCPA and CPRA (California), LGPD (Brazil), PIPEDA (Canada), PDPA (Singapore), PDPB (India), and the Australian Privacy Act. A unified privacy portal at privacy.acmecorp.example allows data subjects in all jurisdictions to exercise their rights.

4. Incident Response

Security incidents must be reported to the Security Team within 1 hour of discovery. Confirmed personal data breaches must be reported to the relevant supervisory authority within 72 hours. Affected data subjects must be notified without undue delay if the breach poses a high risk to their rights and freedoms.

A dedicated Incident Response Team (IRT) is on call 24/7. The IRT includes representatives from Security, Legal, Communications, and Engineering. Tabletop exercises are conducted quarterly.

5. Acceptable Use

Company systems may not be used for personal commercial activity, cryptocurrency mining, or the storage of illegal content. Personal use of email and internet is permitted within reasonable limits. All company devices must have full-disk encryption and automatic screen lock enabled.

A new acceptable use policy for generative AI tools prohibits uploading confidential or regulated data to external AI services without an approved enterprise agreement.

6. Vendor Management

All vendors with access to customer data must undergo a security review before onboarding and annually thereafter. Vendors must provide SOC 2 Type II reports or equivalent. Contracts must include data protection, confidentiality, and breach notification clauses. Critical vendors require quarterly reviews.

7. AI and Machine Learning Governance

All AI and machine learning systems that process personal data must undergo a formal impact assessment before deployment. Model cards and evaluation reports are mandatory. Outputs must not be used to make automated decisions affecting individual rights without human review.

A new AI Governance Committee meets monthly to review new AI initiatives. The Committee includes representatives from Legal, Security, Engineering, and Product. Compliance with the EU AI Act is tracked for all systems deployed in EU jurisdictions.

8. Export Controls

Acme complies with US export control regulations (EAR, ITAR) and EU dual-use regulations. Customers and partners in embargoed countries are screened before onboarding. Restricted party screening is performed monthly against consolidated lists.